المحاضرة الخامسة — المحطة الأولى

# كيف تعمل اتصالات HTTPS ومصافحة TLS؟

التوليفة العبقرية بين التشفير بالمفتاح العام (للأمان) والتشفير المتماثل (للسرعة القصوى)

علامة القفل الخضراء في المتصفح مش معناها إن صاحب الموقع ملاك ومش هينصب عليك! دي معناها بس إن مفيش حد في الشارع يقدر يتجسس على كلمة سرك وهي ماشية في السلك!

كيف تعمل تقنيات التشفير والمصادقة معاً للحفاظ على أمان الاتصال والخدمات عبر الإنترنت؟

## اتصال HTTPS ومصافحة TLS (HTTPS & TLS Handshake Flow)

HTTPS هو بروتوكول HTTP منقول عبر اتصال TLS مؤمّن. يوفر TLS سرية البيانات وسلامتها أثناء النقل، ويساعد المتصفح على التحقق من هوية الخادم واسم النطاق. وتسمى خطوات إنشاء الاتصال الآمن "مصافحة TLS".

قاعدة الامتحان الذهبية: "المفتاح العام للمصادقة والاتفاق على الأسرار بأمان.. والتشفير المتماثل لنقل بيانات الجلسة بسرعة وكفاءة."

## تدفق اتصال HTTPS عبر مصافحة TLS (الشكل 2.1.1 من كتاب الوزارة)

3 خطوات متسلسلة

**المتصفح (العميل)**
يفحص الشهادة ويشتق المفاتيح

⇄ نفق TLS المشفر ⇄

**خادم الويب**
مع المفتاح الخاص السري

### 1. مصافحة TLS — التحقق من الشهادة الرقمية والمفتاح العام

التشفير بالمفتاح العام

← يستقبل ويفحص — الشهادة الرقمية + المفتاح العام — الخادم يرسل ←

أثناء المصافحة يرسل الخادم شهادته، ويتحقق المتصفح من صلاحيتها وسلسلة الثقة وملاءمتها لاسم الموقع لمنع الانتحال.

### 2. مصافحة TLS — تبادل معاملات تبادل المفاتيح واشتقاق مفاتيح الجلسة

التشفير بالمفتاح العام

⇄ المتصفح — معاملات رياضية — المفتاح لا يمر في السلك أبداً! — الخادم ⇄

يتبادل الطرفان معاملات تبادل المفاتيح، ويشتق كل طرف مفتاح الجلسة لديه دون إرسال المفتاح نفسه عبر الشبكة.

### 3. تبادل البيانات — تبادل بيانات الجلسة المحمية بمفاتيح الجلسة

التشفير المتماثل

تصفح — بيانات الجلسة مشفرة بمفتاح الجلسة المشترك — سرعة وأمان

تُحمى بيانات الجلسة بالتشفير المتماثل وآليات سلامة البيانات بسرعة وكفاءة لنقل حجم البيانات الضخم.

**المفتاح العام:** للمصادقة والاتفاق الآمن على مفاتيح الجلسة | **التشفير المتماثل:** لحماية بيانات الجلسة بسرعة وكفاءة

### التشفير بالمفتاح العام (Asymmetric)

- **الدور:** مصافحة البداية فقط (المصادقة والاتفاق على مفتاح الجلسة)
- **الميزة:** أمان فائق ولا يحتاج لإرسال المفتاح السري
- **العيب:** بطيء حسابياً ويستهلك طاقة معالجة أكبر بألف مرة

### التشفير المتماثل (Symmetric)

- **الدور:** حماية كل بيانات الجلسة بعد الاتفاق
- **الميزة:** فائق السرعة وخفيف جداً على المعالج والبطارية
- **العيب:** معضلة تبادل المفتاح بأمان في البداية

**يتبادل اتصال HTTPS جميع بيانات الجلسة باستخدام التشفير بالمفتاح العام؟ (صح أم خطأ؟)**

المحاضرة الخامسة — المحطة الثانية

# المصادقة في الخدمات الفعلية: دروع 2FA و MFA

فئات المصادقة الثلاث: ما تعرفه، ما تملكه، وما أنت عليه — وكيف تحميك عند تسرب كلمة المرور؟

لو كتبت باسوردك 123456 فالمصادقة الثنائية (2FA) هي اللي هتنقذك لما الهاكر يجي يدخل يلاقي الموبايل بيصرخ في جيبك برمز OTP!

### المصادقة الثنائية (2FA)

استخدام عاملين مستقلين من فئتين مختلفتين تماماً لإثبات الهوية (مثل كلمة مرور + رمز على الهاتف).

### المصادقة متعددة العوامل (MFA)

استخدام عاملين أو أكثر من فئات مختلفة، مثل المعرفة والحيازة والسمات الحيوية مجتمعة.

## 1. المعرفة (Knowledge)

ما تعرفه في عقلك (Something you know)

- كلمة المرور (Password)
- رقم PIN السري
- سؤال الأمان

⚠ يمكن تخمينها، أو سرقتها بالهندسة الاجتماعية والتصيد، أو تسريبها من قواعد البيانات.

## 2. الحيازة (Possession)

ما تملكه في جيبك (Something you have)

- رمز OTP المؤقت
- رسالة SMS على هاتفك
- بطاقة الدائرة المتكاملة (IC Card)
- تطبيق المصادقة (Authenticator)

⚠ يمكن سرقة الهاتف أو اعتراض رسائل SMS في هجمات تبديل الشريحة (SIM Swap).

## 3. السمات الحيوية (Inherence)

ما أنت عليه في جسدك (Something you are)

- بصمة الإصبع (Fingerprint)
- التعرف على الوجه (Face ID)
- بصمة قزحية العين (Iris Scan)

⚠ لا يمكن تغييرها أبداً إذا تم اختراقها أو تقليدها بتقنيات التزييف العميق.

## أمثلة الكتاب المدرسي على المصادقة المستخدمة في الخدمات الواقعية

دائماً فئتان مستقلتان

| الخدمة | أمثلة على المصادقة المستخدمة | نوع الثنائية | الهدف الأمني الحقيقي |
|---|---|---|---|
| **الخدمات المصرفية عبر الإنترنت (Online Banking)** | كلمة المرور (المعرفة) + كلمة المرور لمرة واحدة OTP (الحيازة) | **معرفة + حيازة** | حتى لو اخترق أحد حاسوبك وعرف الباسورد، لن يستطيع تحويل مليم بدون الكود المتغير على هاتفك. |
| **تسجيل الدخول إلى وسائل التواصل الاجتماعي (Social Media)** | كلمة المرور (المعرفة) + المصادقة عبر الرسائل القصيرة SMS (الحيازة) | **معرفة + حيازة** | يمنع الاستيلاء على الحساب عند تسرب كلمات المرور من مواقع أخرى. |
| **الدخول إلى مبنى مؤمّن (Secure Facility Entry)** | بطاقة دخول IC ذكية (الحيازة) + بصمة إصبع (السمات الحيوية) | **حيازة + سمات حيوية** | يمنع دخول شخص سرق البطاقة لأنها تتطلب مطابقة بصمة إصبعه الحقيقية. |
| **التسوق الإلكتروني والشراء (E-Commerce Checkout)** | كلمة المرور (المعرفة) + التحقق من هوية بطاقة الائتمان / OTP (الحيازة) | **معرفة + حيازة** | يضمن أن المشتري هو مالك الحساب والبطاقة في نفس الوقت. |

المحاضرة الخامسة — المحطة الثالثة

# دفاع الطبقات وسيناريو الشراء ومختبر قرار المهندس

تكامل التقنيات الأربعة: التشفير، الشهادة، التوقيع الرقمي، والمصادقة (لا أمان مطلق بدون طبقات)

الأمان زي أبواب القلعة: باب خندق، باب حديد، وباب حراس.. مفيش قفل سحري واحد يحمي كل حاجة لوحده!

**لا يأتي الأمان عبر الإنترنت من تقنية واحدة، بل من الجمع بين التشفير والشهادات والتوقيعات والمصادقة بحيث تتم معالجة تهديدات كثيرة في آن واحد (الدفاع في العمق - Defense in Depth).**

## مصفوفة تقنيات الأمان الأربعة وتأثيرها

**التشفير (المتماثل / المفتاح العام)** — التنصت وسرقة البيانات أثناء النقل (Eavesdropping)
يمنع قراءة محتوى الاتصال والتنصت من قِبل أي طرف ثالث.

**الشهادة الرقمية** — انتحال شخصية المواقع والمواقع المزيفة (Impersonation)
تساعد المتصفح على التحقق من هوية الخادم واسم النطاق الذي يتصل به.

**المصادقة الثنائية (2FA)** — اختراق الحسابات عند تسرب كلمات المرور (Unauthorized Login)
تقلل احتمال تسجيل الدخول غير المصرح به باستخدام عاملين مستقلين.

**التوقيع الرقمي** — التلاعب بالرسائل وإنكار تنفيذ المعاملات (Tampering & Repudiation)
يدعم التحقق من سلامة البيانات وهوية الموقّع، ويوفر دليلاً يدعم عدم التنصل (Non-repudiation).

## سيناريو الشراء عبر التسوق الإلكتروني: كيف تتكامل التقنيات الأربعة؟

1. **الدخول إلى المتجر** — التشفير (Encryption)
يبدأ اتصال HTTPS، ويمنع التشفير قراءة محتوى الاتصال من قِبل أي أطراف ثالثة على شبكتك.

2. **فحص هوية المتجر** — الشهادة الرقمية (Digital Certificate)
يتحقق المتصفح تلقائياً من الشهادة الرقمية للمتجر واسم النطاق ليتأكد أنك متصل بالمتجر الحقيقي وليس بموقع احتيالي مقلد.

3. **تسجيل دخول العميل** — المصادقة الثنائية (2FA)
تطلب الخدمة كلمة المرور + رمز OTP على الهاتف لتقليل خطر الدخول غير المصرح به حتى لو سُرقت كلمة المرور.

4. **تأكيد ودفع الطلب** — التوقيع الرقمي و TLS (Digital Signature & TLS)
يحمي TLS سرية وسلامة بيانات الدفع أثناء النقل، ويُستخدم التوقيع الرقمي لإثبات اعتماد أمر الدفع وتفاصيل الفاتورة بدون إمكانية التراجع أو التلاعب.

## فكّر كمهندس: ابحث ثم قرر — بوابة درجات ورسوم المدرسة

تعمل إحدى المدارس في مدينتك على إنشاء بوابة إلكترونية يتحقق من خلالها الطلاب من درجاتهم ويدفعون الرسوم الدراسية. بصفتك مهندس النظم، عليك اختيار طريقة تسجيل دخول الطلاب المناسبة.

**○ الخيار (أ): كلمة مرور فقط**
- سهل وسريع جداً، ولا يتطلب امتلاك الطالب لهاتف ذكي أو خط اتصال.
- ضعيف أمنياً؛ يسهل تخمين الباسورد أو تسريبه والاطلاع على درجات الزملاء والعبث بالرسوم.

**● الخيار (ب): كلمة مرور + OTP يُرسل إلى الهاتف**
- أمان قوي جداً؛ يمنع أي طالب من اختراق حساب زميله حتى لو عرف كلمة مروره.
- قد يواجه الطلاب الذين لا يملكون هواتف ذكية أو خطوط اتصال صعوبة في الدخول.

**الطلاب عموماً (Students)**
✓ حماية خصوصية درجاتهم وبياناتهم المالية من تجسس زملائهم.
✕ خطوة إضافية تستغرق وقتاً للحصول على رمز الـ OTP في كل تسجيل دخول.

**المدرسة الإدارة (School Administration)**
✓ حماية نظام الدفع ومنع الشكاوى الأمنية والتلاعب بالنتائج.
✕ تكلفة إرسال رسائل SMS أو دعم الطلاب الذين يفقدون هواتفهم.

**طالب لا يملك هاتفاً ذكياً (Student without Smartphone)**
✓ ضمان أن بياناته لن تُسرق بسهولة.
✕ عائق وصول حقيقي قد يمنعه من معرفة درجاته إلا إذا وفرت المدرسة بديلاً.

## الخلاصة وإجابة السؤال الرئيسي للمحاضرة

يعتمد الأمان والخدمات الموثوقة عبر الإنترنت على التناغم والتكديس بين التشفير والمصادقة: يستخدم HTTPS بروتوكول HTTP عبر اتصال TLS مؤمّن؛ حيث تساعد الشهادات وآليات المفتاح العام على المصادقة وإنشاء مفاتيح الجلسة، ثم يحمي التشفير المتماثل بيانات الجلسة بسرعة وكفاءة. وتقلل المصادقة الثنائية (2FA) احتمال الدخول غير المصرح به عبر عاملين مستقلين. الحماية الفعالة تتكون من طبقات تقلل المخاطر، ولا تعتمد على تقنية واحدة أو ضمان مطلق.

## بوابة الاختبار الإلكتروني الشامل (رمزين QR) — الدرس 2-1

امسح رمز الـ QR بكاميرا الهاتف لفتح الامتحان مباشرة باللغة العربية أو الإنجليزية.

شاشة اختبار مستقلة ثنائية اللغة

### EG الاختبار باللغة العربية

عربي (RTL)

### GB الاختبار باللغة الإنجليزية

English (LTR)